

RELATÓRIO

Auditoria de Segurança — NexusVora

Data: 29/08/2026

Escopo auditado

Repositório NexusVora, com rotas HTTP, controladores, modelos Eloquent, middleware, views Blade, e-mails, configurações, migrações, arquivos de deploy presentes e histórico Git. Dependências de terceiros em *vendor/* não foram tratadas como código do produto.

Nota metodológica

Stack detectada: PHP 8.2, Laravel 12, Eloquent ORM, autenticação por sessão do Laravel e autorização por middleware auth + admin. Não existe modelo de usuário final, organização ou tenant: o painel é um único domínio administrativo. Assim, isolamento foi mapeado ao acesso administrativo global; IDOR foi verificado em todos os parâmetros de rota com model binding e recursos aninhados; XSS foi mapeado a Blade, e-mails e JavaScript; segredos foram buscados no estado atual e no histórico Git.

Resultado: nenhum achado confirmado

A solicitação exigia reporte apenas de falhas comprovadas. A revisão não encontrou falha explorável nas cinco categorias solicitadas. Portanto, o relatório não força cinco achados artificiais.

Resumo executivo



Pontos fortes verificados

- **Autorização no servidor.** routes/web.php:92-128 aplica auth + admin a todas as rotas do console; app/Http/Middleware/EnsureUserIsAdmin.php:14-16 bloqueia sessão ausente e usuários sem is_admin.
- **Cobertura de objetos aninhados.** ProjectController.php:106-143 confere que a tarefa pertence ao projeto; HourPackageController.php:131-134 e 156-158 conferem os vínculos entrada/pacote e tarefa/pacote.
- **Compartilhamento protegido.** SecureShare usa token aleatório de 48 caracteres (SecureShare.php:32-39), hash para o código de acesso (65-68), criptografia em repouso dos dados compartilhados (25-30) e valida expiração (SecureShareAccessController.php:38-46).
- **XSS tratado no conteúdo de e-mail.** resources/views/emails/contact.blade.php:19 escapa a mensagem com e() antes de aplicar nl2br; Blade usa escape padrão nos demais campos revisados.
- **Segredos fora do Git.** .env está ignorado e não é rastreado; nenhuma assinatura de chave privada ou token de serviço foi encontrada no código do produto ou no histórico Git.

Pontos fracos e recomendações preventivas

Não há vulnerabilidade confirmada nesta revisão. As melhorias abaixo são preventivas e não representam achados acionáveis.

- P1.** Adicionar testes de feature para as rotas administrativas, especialmente a negação a usuário autenticado sem is_admin e a checagem de recursos aninhados.
- P2.** Se o produto evoluir para múltiplos operadores, introduzir organization_id ou políticas por dono antes de conceder papéis não administrativos; o modelo atual é global por projeto.
- P3.** Manter validação de URL na criação de compartilhamento seguro e considerar permitir somente https se links HTTP não forem necessários.

Detalhamento por categoria

Categoria	Resultado	Evidência de cobertura
Banco sem tranca	CORRETO / não aplicável	Não há tenant, workspace ou usuário final modelado. O único escopo protegido é o console administrativo global, servido por auth + admin.
Permissão definida no navegador	CORRETO	Não há gates de papel no frontend. As operações privilegiadas são guardadas no backend por routes/web.php:92-128 e EnsureUserIsAdmin.php:14-16.
IDOR	CORRETO	Todos os handlers com ID foram percorridos. Bindings do console exigem admin; recursos aninhados validam pertencimento onde há relação pai-filho.
Chaves expostas	CORRETO	Busca no código, configs, documentação, arquivos públicos e histórico Git não confirmou segredo hardcoded. .env é ignorado e fica fora de public_html.
Inputs sem tratamento / XSS	CORRETO	Não há HTML bruto de entrada do usuário. O único raw output de mensagem usa e(); URLs compartilhadas são validadas como url antes de renderizar em href.

Tabela de achados: não aplicável - não há achados confirmados para listar.

Cobertura e condições de explorabilidade

A análise considerou as 63 rotas reportadas por `php artisan route:list`, todos os controladores em `app/Http/Controllers`, modelos, middleware, e-mails, views Blade, JavaScript próprio, migrações e configurações. O repositório estava com alterações locais preexistentes; elas foram apenas lidas e não modificadas.

A rota pública de compartilhamento é deliberadamente acessível por token. O token é de alta entropia e o conteúdo só é mostrado após código de acesso e antes da expiração. A limitação de tentativas por IP está em routes/web.php:57-59.

ISSUES PARA O GITHUB

Não há issues acionáveis: nenhum achado confirmado atingiu o limiar de reporte. Para preservar a regra de não criar spam, nenhum bloco de issue é incluído.

--- ISSUE 0 ---

Nenhuma issue gerada. A auditoria não confirmou falhas nas categorias solicitadas.

--- FIM ISSUE 0 ---